

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-16 09:00 WIB

Top 5 Highlights

- The vulnpocalypse rains iBugs down on Apple with record-setting number of patches
- Acronis warns of actively exploited flaw in its cPanel backup plugin
- Oracle September 2026 Critical Security Patch Update addresses 672 CVEs
- Malcious Admin Menu Editor Pro plugin backdoors 1,500 WordPress sites
- Microsoft Issues Emergency Fixes After Massive Patch Tuesday

Threat Intelligence (10)

01. Malicious Admin Menu Editor Pro plugin backdoors 1,500 WordPress sites

Malicious versions of the Admin Menu Editor Pro plugin for WordPress have been distributed to more than 200 customers after a threat actor compromised the maintainer's website and pushed updates that created a hidden user account. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/malicious-admin-menu-editor-pro-plugin-backdoors-1-500-wordpress-sites/>

02. KREMLIN Banking Malware Hijacks Chrome and Edge to Steal Credentials and Session Tokens

Cybersecurity researchers have shed light on a previously undocumented Brazilian banking malware operation that delivers a toolkit called KREMLIN. Elastic Security Labs is tracking the activity under the moniker REF9334. Active since at least May 2025, the threat actor has used lures that impersonate a dozen Brazilian banks and install a malicious browser e...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/kremlin-banking-malware-hijacks-chrome.html>

03. Iranian spies hit Windows machines with Chosen Brick data-stealing malware

'Enemies of the regime' on notice

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/09/15/iranian-spies-hit-windows-machines-with-chosen-brick-data-stealing-malware/5296646>

04. VectraRAT Can Hack Windows Enterprises for \$250 per Month

The full-service malware-as-a-service (MaaS) platform offers a Windows implant, command-and-control (C2) infrastructure, and an operator panel for comprehensive remote access.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/endpoint-security/vectrarat-hack-windows-enterprises>

05. Iranian Hackers Use Telegram-Controlled Malware to Spy on Dissidents and Journalists

Cybersecurity agencies in the United States, the United Kingdom, and the Netherlands have detailed a Windows malware that they say Iran's intelligence service uses to spy on dissidents, journalists, and activists around the world. The malware is controlled via the Telegram messaging app and can copy a target's emails and chat messages, take screenshots, and...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/iranian-hackers-use-telegram-controlled.html>

06. BambooToken Malware Uses MQTT to Control Windows and Linux Systems

Cybersecurity researchers have disclosed details of a multi-platform campaign that uses the Message Queueing Telemetry Transport (MQTT) protocol as a communication channel to control Windows and Linux systems. The emerging malware family, codenamed BambooToken, is assessed to be active since at least February 2023 and put to use in attacks targeting organiz...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/bambootoken-malware-uses-mqtt-to.html>

07. BambooToken malware controls Windows and Linux systems via MQTT

A previously unknown malware framework called BambooToken, active since at least 2023, is now using the Message Queueing Telemetry Transport (MQTT) protocol to communicate with Windows and Linux systems. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/bambootoken-malware-controls-windows-and-linux-systems-via-mqtt/>

08. HBO Max's verified Reddit account hijacked to spread malware

Cybercriminals used HBO Max's verified Reddit account to run 108 malicious ads that tricked people into installing information stealers.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/09/hbo-maxs-verified-reddit-account-hijacked-to-spread-malware>

09. Attack Chains, Not Just Attack Surfaces: Why Testing Individual Techniques Misses the Point

Introduction Security teams have gotten pretty good at testing against what can hurt them. Can this EDR agent catch this payload? Will my organization fail the phishing simulation? Does this SIEM rule fire on this particular technique? And, in more mature organizations, this testing happens continuously rather than as a one-off exercise. But no matter how m...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/09/attack-chains-not-just-attack-surfaces.html>

10. Attackers hijack HBO Max's Reddit account for 48-hour malvertising blitz

Attackers compromised the verified official HBO Max Reddit account, u/hbomax, and used its trusted advertising status to launch a ClickFix campaign targeting macOS and Windows devices with information-stealing malware. Screenshot of the fraudulent ad (Source: Alex Cutts) ClickFix has been rising in popularity among cybercriminals. It's a social engineering...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.helpnetsecurity.com/2026/09/15/hbo-max-reddit-account-clickfix-infostealer-malware/>

Latest Vulnerabilities (10)

01. The vulnpocalypse rains iBugs down on Apple with record-setting number of patches

September Patch Tuesday part 2?

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/09/15/the-vulnpocalypse-rains-ibugs-down-on-apple-with-record-setting-number-of-patches/5296679>

02. Acronis warns of actively exploited flaw in its cPanel backup plugin

Acronis disclosed a high-severity Linux local privilege escalation vulnerability in its backup plugin for cPanel, WebHost Manager (WHM), and Plesk that may be exploited in the wild. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/acronis-warns-of-actively-exploited-flaw-in-it-s-cpanel-backup-plugin/>

03. Oracle September 2026 Critical Security Patch Update addresses 672 CVEs

Oracle addresses 672 CVEs in its September 2026 Critical Security Patch Update with 673 patches, including 104 critical updates. Key Takeaways The September 2026 Critical Security Patch Update (CSPU) contains fixes for 672 unique CVEs in 673 security updates 104 issues (15.5% of all patches) were assigned a critical severity rating Oracle E-Business Suite r...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.tenable.com/blog/oracle-september-2026-critical-security-patch-update-addresses-672-cves>

04. Microsoft Issues Emergency Fixes After Massive Patch Tuesday

You can't make an omelet without breaking a few eggs, and you can't patch nearly 1,000 CVEs without a few glitches.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/application-security/microsoft-emergency-fixes-patch-tuesday>

05. Critical Cisco Secure Email Gateway zero-day gives attackers root access

Cisco released emergency patches for a critical vulnerability in its Secure Email Gateway appliance that could allow attackers to take over the device by simply sending malicious crafted emails to users. The flaw was already being exploited in the wild when the fixes were released. Tracked as CVE-2026-76461, the vulnerability is described by Cisco as an SQL...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4222391/critical-cisco-secure-email-gateway-zero-day-gives-attackers-root-access.html>

06. Black Hat USA 2026 | The 'Breaking' News: The OpenAI-Hugging Face Incident

The 'Breaking' News: The OpenAI-Hugging Face Incident - A Technical Reconstruction and Its Implications for AI At this Black Hat USA 2026 talk, OpenAI security engineers and researchers will reconstruct the OpenAI-Hugging Face incident and examine its implications for AI security, cyber resilience, and alignment. Throughout the session, they will share insi...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/vulnerabilities-threats/bhusa26huggingfacetalk>

07. Patched VMware vCenter bug targeted in ransomware campaigns

Ransomware groups exploit a critical VMware vCenter bug just seven weeks after patch released.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/news/patched-vmware-vcenter-bug-targeted-in-ransomware-campaigns>

08. Before You Patch. Why Patch Reliability Matters for Confident Deployment

Executive Summary Microsoft's September 2026 security updates, KB5124008 and KB5124012, have been linked to USB audio failures on some Windows systems, highlighting the operational risk that can accompany security patching. Qualys TruRisk Eliminate classified both updates as Low Reliability, signaling the need for additional validation before production dep...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://blog.qualys.com/product-tech/2026/09/15/before-you-patch-why-patch-reliability-matters-for-confident-deployment>

09. Cisco email security boxes can be rooted by... an email

Attackers already exploiting the critical flaw, and Cisco warns they may be able to cover their tracks once they're in

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/09/15/cisco-email-security-boxes-can-be-rooted-by-an-email/5296604>

10. \$1 Million Sandbox Challenge Uncovers Linux Kernel Flaws

AI-assisted researchers flooded Vercel with reports, forcing the company to automate vulnerability triage. The post \$1 Million Sandbox Challenge Uncovers Linux Kernel Flaws appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/1-million-sandbox-challenge-uncovers-linux-kernel-flaws/>

Data Breach & Cybercrime (10)

01. CenterPoint Energy confirms customer data stolen in cyberattack

CenterPoint Energy disclosed a breach compromising some customers' personal information after an attacker leaked data allegedly stolen from the utility company. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/centerpoint-energy-confirms-customer-data-stolen-in-cyberattack/>

02. Texas Utility CenterPoint Energy Confirms Breach After Hacker Leaks Data

A hacker claims to have stolen 7.5 million customer records after breaching the company's systems. The post Texas Utility CenterPoint Energy Confirms Breach After Hacker Leaks Data appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/texas-utility-centerpoint-energy-confirms-breach-after-hacker-leaks-data/>

03. Most Fraudulent Hires Receive Credentials Before Detection

A new report highlights the vast growth in fraudulent candidates, presenting significant insider threat challenges to organizations

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/fraudulent-hires-credentials/>

04. Most Firms Unable to Recover Quickly from Ransomware

Fenix24 found only four of more than 800 clients came close to stated ransomware recovery targets of 24-48 hours

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/four-of-800-clients-hit-ransomware/>

05. F5 Bot Defense uses real-time risk scoring to detect fraud and abuse

F5 has announced enhancements to F5 Distributed Cloud Bot Defense, introducing new device intelligence capabilities and specialized agentic AI protections. These capabilities bring persistent device context and continuous risk decisioning to application security, giving organizations the real-time agent management designed to help welcome trusted digital in...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/15/f5-distributed-cloud-bot-defense-enhancements/>

06. Black Axe Members Extradited to US Over Internet Fraud Claims

Alleged Black Axe leaders extradited to the US over romance scams, BEC and money laundering claims

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/black-axe-members-extradited-us/>

07. Swiss court sentences 52-year-old Ukrainian ransomware dev to nearly 13 years in the cooler

The man allegedly wrote the code that powered the Lockergoga, MegaCortex, and Nefilim operations

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.theregister.com/security/2026/09/15/swiss-court-sentences-52-year-old-ukrainian-ransomware-dev-to-nearly-13-years-in-the-cooler/5296482>

08. Globalgig expands managed security portfolio to protect enterprise AI

Globalgig has expanded its managed security portfolio to cover enterprise AI, bringing together services that discover, assess, and protect the AI applications, agents, models, and data enterprises are putting into production. The services are delivered through the same managed model that already covers the edge, endpoints, identities, and security operatio...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.helpnetsecurity.com/2026/09/15/globalgig-expands-managed-security-with-ai-protection/>

09. eBook: Identity-First Threat Intelligence

Attackers increasingly bypass traditional defenses by logging in with credentials that have already been stolen, exposed, or sold on the Dark Web. As infostealer malware accelerates credential theft, organizations need greater visibility into identity risk across Active Directory, IAM, and authentication environments. Download the e-book to explore: How inf...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/15/enzoic-ebook-identity-first-threat-intelligence/>

10. [+24h Old] Suspected Black Axe gang leaders face cybercrime charges in the US

Five alleged leaders of the Black Axe cybercrime syndicate, known for its involvement in global-scale cyber-enabled financial fraud, have been extradited to the United States to face wire fraud and money laundering charges. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/black-axe-gang-members-extradited-to-us-face-cybercrime-charges/>